

Zenith Global | Enterprise Risk & Governance Decision Tree

CLASSIFICATION: INTERNAL / CORPORATE GOVERNANCE

AUTHORITY: Matt Watkins, GRC advisor/ analyst

Workflow Tree Overview

[1. THREAT & GAP IDENTIFICATION] —► [2. TRIAGE & SCORING] —► [3. EXECUTIVE DIRECTION] —► [4. TACTICAL REMEDIATION] —► [5. CONTINUOUS SURVEILLANCE]

Step 1: Identification (Detection & Discovery)

- **Objective:** Surface vulnerabilities, unauthorized system access, or compliance anomalies across Zenith Global's global infrastructure (cloud environments, regional data centers, and endpoint networks).
- **Triggers:**
 - Automated intrusion detection systems (IDS) and Endpoint Detection & Response (EDR) telemetry.
 - Internal audits, automated vulnerability scans, and external red-team/threat intelligence reports.
- **Action:** Automatically open an incident/risk record in Zenith Global's central **GRC Risk Register**, detailing the affected infrastructure asset, network zone, and preliminary impact radius.

Step 2: Evaluation (Risk & Severity Assessment)

- **Objective:** Quantify the immediate danger and business impact to Zenith Global's operations or intellectual property.
- **Scoring Formula:**
$$\text{Risk Score} = \text{Likelihood} \times \text{Impact}$$
- **Escalation Rules:**
 - **Low / Medium Risk:** Routes to standard DevSecOps and IT operations queues.
 - **High / Critical Risk (e.g., zero-day exploit, active compromise, or high-value asset exposure):** Triggers immediate escalation to IT Director and the Security Incident Response Team (SIRT).

Step 3: Decision (Governance & Strategy)

Mark Daleman and executive leadership select one of four mandatory handling strategies:

1. **Mitigate (Remediate):** Authorize immediate engineering resources to patch, isolate, or neutralize the vulnerability (Default Directive).
2. **Accept (Risk Exemption):** Acknowledge operational risk due to mission-critical business continuity constraints. Requires a signed Policy Exception Request and executive sign-off with a mandatory expiry timestamp.
3. **Transfer:** Offload operational liability via cyber risk insurance coverage or third-party managed security services.
4. **Avoid (Decommission):** Instantly sever, isolate, or decommission the offending subsystem, service, or third-party integration from Zenith Global's production grid.

Step 4: Action (Remediation & Execution)

- **When Mitigating:**
 - Issue a high-priority ticket in Jira Security linked directly to the risk entry.
 - Apply strict remediation SLAs (e.g., 24–48 hours for Critical/Exploitable gaps; 30 days for High-severity vulnerabilities).
- **When Accepting:**
 - Log the exception into Zenith Global's secure GRC portal.
 - Set an automated expiration review flag (maximum 90 to 360 days) to prevent permanent unmonitored risk.

Step 5: Monitoring (Verification & Surveillance)

- **Technical Validation:** Execute mandatory rescan jobs or automated penetration tests against affected nodes to verify the fix is active and stable.
- **Executive Oversight:** Stream live status metrics directly to IT director and **Executive Compliance Dashboard**.
- **Closure:** Formally close out the risk ticket upon verification, retaining full cryptographic audit logs for regulatory and internal security compliance.